

第 4 章作业

1.什么是数据库的安全性？

答：数据库的安全性是指保护数据库以防止不合法使用所造成的数据泄露、更改或破坏。

2.举例说明对数据库安全性产生威胁的因素。

答：（1）非授权用户对数据库的恶意存取和破坏。一些黑客和犯罪分子在用户存取数据库时猎取用户名和用户口令，然后假冒合法用户偷取、修改甚至破坏用户数据。

（2）数据库中重要或敏感的数据被泄露。黑客和敌对分子千方百计盗窃数据库中的重要数据，一些机密信息被暴露。

（3）安全环境的脆弱性。操作系统安全的脆弱，网络协议安全保障的不足等都会造成数据库安全性的破坏。

3.试述信息安全标准的发展历史，试述 CC 评估保证级划分的基本内容。

答：1985 年美国国防部颁布 TCSEC，此后 10 年里，不同的国家都开始启动开发建立在 TCSEC 概念上的评估准则，如 1991 年欧洲的 ITSEC，1993 年加拿大的 CTCPEC，1993 美国的 PC 草案等。为满足全球 IT 市场上互认标准化安全评估结果的需要，CTPEC、FC。TCSEC 和 ITSEC 的发起组织于 1993 年开始联合行动，即 CC 项目，目前 CC 已经基本取代了 TCSEC，成为评估信息产品安全性的主要标准。

评估保证级	定义
EAL1	功能测试
EAL2	结构测试
EAL3	系统地测试和检查
EAL4	系统地设计、测试和检查

EAL5	半形式化设计和测试
EAL6	半形式化验证的设计和测试
EAL7	形式化验证的设计和测试

4.试述实现数据库安全性控制的常用方法和技术。

答：（1）用户身份鉴别：系统内部记录着所有合法用户的标识，系统鉴别是指由系统提供一定的方式让用户表示自己的名字或身份，每次用户要求进入系统时，由系统进行核对，通过鉴定后才提供使用数据库管理系统的权限。

（2）存取控制：系统提供用户权限定义和合法权限检查功能，用户只有获得某种权限才能访问数据库中的某些数据。

（3）视图机制：为不同的用户定义不同的视图，把数据对象限定在一定的范围内，把要保密的数据对无权存取的用户隐藏起来，从而自动对数据提供一定程度的安全保护。

（4）审计：把用户对数据库的所有操作自动记录下来放入审计日志中，审计员可以利用审计日志监控数据库中的各种行为，重现导致数据库现有状况的一系列事件，找出非法存取数据的人、时间等。

（5）数据加密：根据一定的算法将明文变换为密文，从而使得不知道解密算法的人无法获知数据的内容。

5.什么是数据库中的自主存取控制方法和强制存取控制方法？

答：自主存取控制方法：用户对于不同的数据库对象有不同的存取权限，不同的用户对同一对象也有不同的权限，而且用户还可将其拥有的存取权限转授给其他用户。

强制存取控制方法：每一个数据对象被标以一定的密级，每一个用户也被授予某一级别的许可证，对于任意一个对象，只有具有合法许可证的用户才可以存取。

6.对下列两个关系模式：

学生 (学号, 姓名, 年龄, 性别, 家庭住址, 班级号)

班级 (班级号, 班级名, 班主任, 班长)

使用 GRANT 语句完成下列授权功能:

(1) 授予用户 U1 对两个表的所有权限, 并可给其他用户授权。

答: GRANT ALL PRIVILEGES ON TABLE 学生,班级 TO U1 WITH GRANT OPTION;

(2) 授予用户 U2 对学生表具有查看权限, 对家庭住址具有更新权限。

答: GRANT SELECT,UPDATE(家庭住址) ON TABLE 学生 TO U2;

(3) 将对班级表查看权限授予所有用户。

答: GRANT SELECT ON TABLE 班级 TO PUBLIC;

(4) 将对学生表的查询、更新权限授予角色 R1。

答: GRANT SELECT,UPDATE ON TABLE 学生 TO R1;

(5) 将角色 R1 授予用户 U1, 并且 U1 可继续授权给其他用户。

答: GRANT R1 TO U1 WITH ADMIN OPTION;

7.今有以下两个关系模式:

职工 (职工号, 姓名, 年龄, 职务, 工资, 部门号)

部门 (部门号, 名称, 经理名, 地址, 电话号)

请用 SQL 的 GRANT 和 REVOKE 语句 (加上视图机制) 完成以下授权定义或存取控制功能:

(1) 用户王明对两个表有 SELECT 权限。

答: GRANT SELECT ON TABLE 职工,部门 TO 王明;

(2) 用户李勇对两个表有 INSERT 和 DELETE 权限。

答: GRANT INSERT,DELETE ON TABLE 职工,部门 TO 李勇;

(3) 每个职工只对自己的记录有 SELECT 权限。

答: GRANT SELECT ON TABLE 职工 WHEN USER()=NAME TO ALL;

(4) 用户刘星对职工表有 SELECT 权限, 对工资字段具有更新权限。

答: GRANT SELECT,UPDATE(工资) ON TABLE 职工 TO 刘星;

(5) 用户张新具有修改这两个表的结构权限。

答: GRANT ALTER TABLE ON TABLE 职工,部门 TO 张新;

(6) 用户周平具有对两个表的所有权限(读、插、改、删数据), 并具有给其他用户授权的权利。

答: GRANT ALL PRIVILEGES ON TABLE 职工,部门 TO 周平 WITH GRANT OPTION;

(7) 用户杨兰具有从每个部门职工中 SELECT 最高工资、最低工资、平均工资的权限, 他不能查看每个人的工资。

答: CREATE VIEW 部门工资 AS SELECT 部门.名称,MIN(工资),AVG(工资) FROM 职工,部门 WHERE 职工.部门号=部门.部门号 GROUP BY 职工.部门号;

GRANT SELECT ON TABLE 部门工资 TO 杨兰;

8.针对习题 7 中 (1) ~ (7) 的每一种情况, 撤销各用户所授予的权限。

答: (1) REVOKE SELECT ON TABLE 职工,部门 FROM 王明;

(2) REVOKE INSERT,DELETE ON TABLE 职工,部门 FROM 李勇;

(3) REVOKE SELECT ON TABLE 职工 WHEN USER()=NAME FROM ALL;

(4) REVOKE SELECT,UPDATE ON TABLE 职工 FROM 刘星;

(5) REVOKE ALTER TABLE ON TABLE 职工,部门 FROM 张新;

(6) REVOKE ALL PRIVILEGES ON TABLE 职工,部门 FROM 周平;

(7) REVOKE SELECT ON TABLE 部门工资 FROM 杨兰;

DROP VIEW 部门工资;

9.解释强制存取控制机制中主体、客体、敏感度标记的含义。

答：主体是系统中的活动实体，既包括数据库管理系统所管理的实际用户，也包括代表用户的各进程。

客体是系统中的被动实体，是受主体操纵的，包括文件、基本表、索引、视图等。

对于主体和客体，数据库管理系统为它们每个实例（值）指派一个敏感度标记，被分为若干等级。主体的敏感度标记称为许可证级别，客体的敏感度标记称为密级。

10.举例说明强制存取控制机制是如何确定主体能否存取客体的。

答：主体对任何客体的存取遵循以下规则：

（1）仅当主体的许可证级别大于或等于客体的密级时，该主体才能读取相应的客体。

（2）仅当主体的许可证级别小于或等于客体的密级时，该主体才能写相应的客体。

设要控制存取的数据是元组，有基本表如下：

SNO	CLASSIFICATION
S1	秘密
S2	机密
S3	绝密

假设用户 U1 和 U2 的许可证级别分别为机密和秘密，则根据规则用户 U1 能读取元组 S1 和 S2，可修改元组 S2 和 S3，用户 U2 能读取元组 S1，修改元组 S1，S2 和 S3。

11.什么是数据库的审计功能，为什么要提供审计功能。

答：审计功能把用户对数据库的所有操作自动记录下来放入审计日志中。

因为任何系统的安全保护措施都不是完美无缺的，蓄意盗窃破坏数据的人总可能存在。审计员可以利用审计日志监控数据库中的各种行为，重现导致数据库现有状况的一系列事件，找

出非法存取数据的人、时间和内容等。还可以通过对审计日志分析，对潜在的威胁提前采取措施加以防范。

